

Penetration Testing Report

Mediroza General Hospital — Web Application Black-Box Assessment

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Full Black-Box Penetration Test
Batch / Reference	B083 — Week 4
Duration	5 Days
Tester Name	Romaisa Majid
Report Date	1 October, 2026
Authorization	Written authorization granted by the client for security testing of the stated web infrastructure
Classification	CONFIDENTIAL — Authorized Personnel Only

This report documents a penetration test conducted against the Mediroza General Hospital web application in a controlled, authorised environment. The techniques described were performed strictly within agreed scope and must never be applied to any system without explicit written permission from the owner.

1. Executive Summary

Networkwalks was engaged to perform a black-box penetration test against the Mediroza General Hospital web application, hosted at <https://medirozahospital.com>. The objective was to identify exploitable vulnerabilities, demonstrate their real-world impact through controlled exploitation, and report findings with actionable remediation guidance.

The assessment identified a chain of seven vulnerabilities that, combined, allowed an unauthenticated attacker to bypass authentication, access confidential patient laboratory reports, recover their contents by defeating weak file-level password protection, and ultimately locate and download a full, unprotected database backup. That backup exposed personally identifiable information and salary data for all 30 hospital staff members, along with confidential shareholder records for the hospital.

The overall risk to the client is rated Critical. The root cause is a combination of insufficient input validation (SQL injection), absent authorization checks, weak cryptographic practices, and poor server-side hygiene (a legacy directory left live and referenced in robots.txt). Each of these issues is individually serious; together they form a complete attack path from an anonymous visitor to full compromise of sensitive patient, staff, and corporate data.

Summary of Findings

#	Finding	Risk Rating
1	Username Enumeration on Login Form	Medium
2	SQL Injection — Authentication Bypass	Critical
3	Broken Access Control — Unauthorized Access to Patient PDF Reports	High
4	Weak Encryption / Crackable Passwords on PDF Reports	High
5	Information Disclosure via robots.txt	Low
6	Legacy Directory Left Active and Publicly Accessible	Medium
7	Sensitive Data Exposure — Unprotected Database Backup File	Critical

Immediate priority should be given to the two Critical findings (SQL injection and the exposed database backup), as either alone is sufficient for a full data breach.

2. Scope and Methodology

2.1 Scope

Testing was limited strictly to the target domain medirozahospital.com and its web application. The following were explicitly out of scope: social engineering of staff, any form of denial-of-service testing, and testing of systems or domains not named in the authorization. The client provided written authorization covering the full engagement.

2.2 Methodology

The engagement followed a standard black-box methodology, treating the application as an anonymous external attacker would encounter it, with no credentials or internal knowledge provided in advance.

- Reconnaissance — passive and active information gathering against the target domain, including inspection of standard disclosure files such as robots.txt.
- Mapping and enumeration — identification of exposed entry points, including the application's login mechanism, and analysis of its behavior for logical weaknesses.
- Vulnerability identification — testing of input handling on authentication fields and other user-controllable parameters.
- Exploitation — controlled exploitation of identified weaknesses to demonstrate real impact, limited to what was necessary to prove each finding.
- Post-exploitation analysis — examination of retrieved files (including metadata and properties) to identify further exposure, and cracking of weak file-level protections.
- Reporting — documentation of all findings with evidence, risk ratings, and remediation guidance.

2.3 Tools Used

Tool	Purpose
Web browser / manual testing	Reconnaissance, login behaviour analysis, manual SQL injection testing
robots.txt review	Identification of disclosed but unlinked directories
Networkwalks Hash Calculator	Hash identification / generation for cracking PDF passwords
John the Ripper	Offline dictionary/brute-force cracking of weak PDF passwords
AI-assisted analysis tooling	Data analysis and report drafting, as permitted by the engagement rules

2.4 Limitations

As a 5-day, black-box engagement conducted without prior credentials or architectural documentation, testing depth was bounded by the time available and by the agreed rules of engagement (no social engineering, no denial-of-service, no out-of-scope testing). Findings reflect vulnerabilities identified within that window and should not be read as an exhaustive guarantee that no further issues exist.

3. Findings and Proof of Exploitation

Findings are presented in the order they were chained during the engagement. Each finding includes a description, reproduction steps, evidence, and impact. Risk ratings and remediation are summarised in Sections 4 and 5.

Finding 1: Username Enumeration on Login Form

MEDIUM

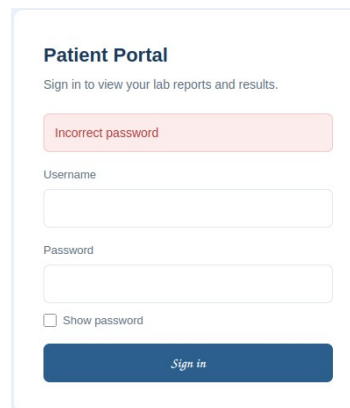
Description

The application's login page responds differently depending on whether a submitted username exists in the system. By observing these differences (error message wording, response timing, or HTTP status), an attacker can confirm valid usernames without any credentials, including the high-value account admin.

Steps to Reproduce

- Submit a range of candidate usernames to the login form, including common administrative names.
- Compare the application's response for each submission (error text, response time, or page behaviour).
- Confirm that the response for "admin" differs from the response for a clearly invalid username, validating it as a real account.

Evidence



The screenshot shows a web form titled "Patient Portal" with the instruction "Sign in to view your lab reports and results." A red error message "Incorrect password" is displayed above the input fields. The form contains a "Username" field, a "Password" field, a "Show password" checkbox, and a "Sign in" button.

Impact

On its own, username enumeration narrows an attacker's target list and is a precursor to credential stuffing, password spraying, or — as demonstrated in Finding 2 — targeted authentication bypass against a known-valid account.

Finding 2: SQL Injection — Authentication Bypass

CRITICAL

Description

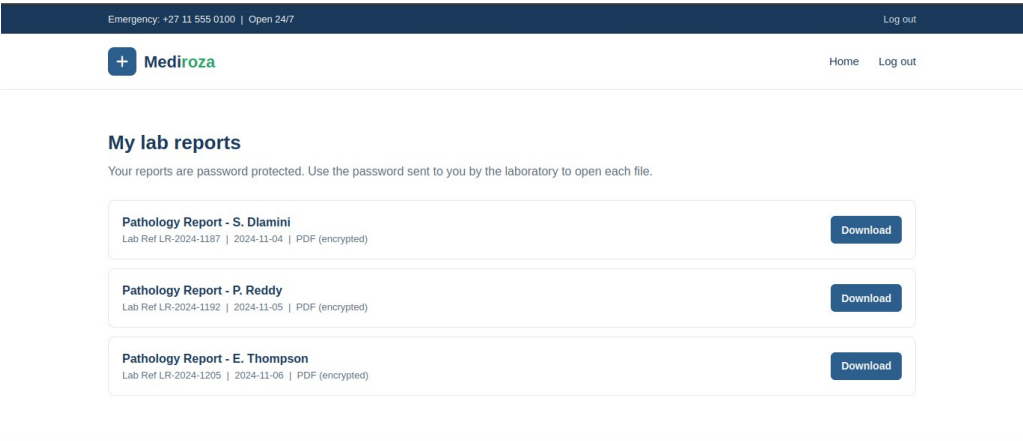
The username/userid parameter on the login form is not properly sanitised before being used in a backend SQL query. Supplying the classic authentication-bypass payload `admin'--` alters the structure of the underlying SQL statement, commenting out the password check and allowing the attacker to authenticate as the admin account confirmed in Finding 1, without knowing its password.

Steps to Reproduce

- Navigate to the application's login page.
- In the username/userid field, submit the payload: `admin'--` (leaving the password field blank or with any value).

- Submit the form and observe that the application grants an authenticated session as the admin account, confirming the injection altered the query logic.
- Verify access by browsing to an authenticated-only resource.

Evidence



Impact

This is a critical, unauthenticated vulnerability. It gives any anonymous visitor full administrative access to the application with no valid credentials, and serves as the initial access vector for the entire attack chain documented in this report, including retrieval of confidential patient PDF reports in Finding 3.

**Finding 3: Broken Access Control —
Unauthorized Access to Patient PDF Reports**

HIGH

Description

Once authenticated via the SQL injection in Finding 2, the application did not apply any further authorization checks before serving three confidential patient laboratory report PDFs. A properly segmented application would validate that the authenticated identity is actually entitled to view specific patient records, rather than trusting session state alone.

Steps to Reproduce

- Using the admin session obtained in Finding 2, browse to the area of the application that lists or serves patient lab reports.
- Request/download the three confidential patient PDF lab reports.
- Confirm that no additional patient-specific authorization check (beyond having any authenticated session) was enforced before the files were served.

Evidence

```
romimajid@romimajid-Vostro-3559:~$ wget https://medirozahospital.com/patient/download.php?id=1
--2026-10-01 22:59:15-- https://medirozahospital.com/patient/download.php?id=1
Resolving medirozahospital.com (medirozahospital.com)... 199.188.201.16
Connecting to medirozahospital.com (medirozahospital.com)|199.188.201.16|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: login.php [following]
--2026-10-01 22:59:16-- https://medirozahospital.com/patient/login.php
Reusing existing connection to medirozahospital.com:443.
HTTP request sent, awaiting response... 200 OK
Length: 2226 (2.2K) [text/html]
Saving to: 'download.php?id=1'

download.php?id=1      100%[=====>]  2.17K  --.-KB/s   in 0.002s

2026-10-01 22:59:17 (1.40 MB/s) - 'download.php?id=1' saved [2226/2226]
```

Impact

Any account compromised through authentication weaknesses — not only via SQL injection, but also stolen credentials or session tokens — immediately gains access to confidential patient health records, a direct breach of patient confidentiality and likely data-protection obligations.

Finding 4: Weak Encryption / Crackable Passwords on PDF Reports

HIGH

Description

The three patient PDF lab reports retrieved in Finding 3 were password-protected, but the passwords used were weak enough to be recovered offline. Password hashes/protection were analysed using the Networkwalks Hash Calculator and cracked using John the Ripper, fully recovering the contents of all three files. Not all three files used an identical approach, requiring adjustment of technique per file.

Steps to Reproduce

- Extract the password hash/protection data from each of the three retrieved PDF files.
- Identify the hash/protection type using the Networkwalks Hash Calculator.
- Run John the Ripper against each file using an appropriate wordlist/ruleset.
- Recover the plaintext password for each file and open the documents, repeating with an adjusted approach where the first method did not succeed.

Impact

Weak, easily-guessable passwords provide negligible real-world protection once a file is exfiltrated. Combined with Finding 3, this means confidential patient lab results are fully exposed in practice, not just in theory.

Finding 5: Information Disclosure via robots.txt

LOW

Description

The application's robots.txt file lists a directory path that is intended to be hidden from search engine indexing. robots.txt is a publicly fetchable, unauthenticated file, so rather than hiding the directory, it directly advertises its existence and location to anyone who requests it — including attackers who, unlike well-behaved search engine crawlers, will not respect the Disallow directive.

Steps to Reproduce

- Request <https://medirozahospital.com/robots.txt> directly in a browser.
- Review the Disallow entries for paths that appear to reference older or internal functionality.
- Note the disclosed path for follow-up investigation (see Finding 6).

Evidence

```
← → ↻ medirozahospital.com/robots.txt

# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Impact

By itself this is a low-severity disclosure issue, but it was the direct pivot point that led to discovery of the still-active legacy directory in Finding 6, and ultimately the exposed database backup in Finding 7.

Finding 6: Legacy Directory Left Active and Publicly Accessible

MEDIUM

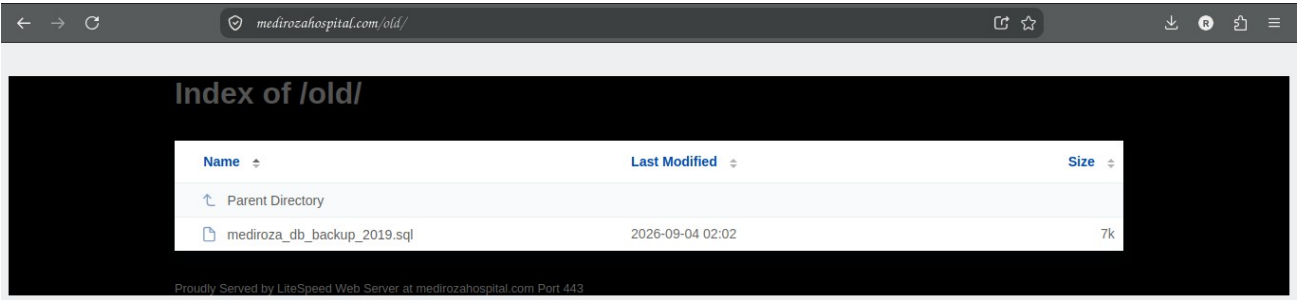
Description

The directory disclosed via robots.txt (User-agent: Disallow: /patient/, Disallow: /staff/, Disallow: /old/) was expected to be decommissioned but was found to still be live and reachable on the production server. Leaving old infrastructure online after it is no longer actively maintained is a common source of forgotten, under-patched, and over-permissioned exposure.

Steps to Reproduce

- Browse directly to the path disclosed in robots.txt.
- Confirm the directory is live and returns content rather than a 404/403 error.
- Enumerate the directory's contents for accessible files.

Evidence



Impact

Legacy infrastructure left online bypasses whatever hardening or review was applied to the current production environment. In this engagement it directly exposed the sensitive database backup documented in Finding 7.

Finding 7: Sensitive Data Exposure — Unprotected Database Backup File

CRITICAL

Description

Within the legacy directory identified in Finding 6, a raw SQL database backup file (mediroza_db_backup_2019.sql) was found publicly accessible with no authentication. The backup is explicitly labelled as containing confidential staff and shareholder records and includes two tables: staff (30 records) and shareholders (10 records).

Steps to Reproduce

- Access the legacy directory identified in Finding 6 and locate the backup file.
- Download mediroza_db_backup_2019.sql without authentication.
- Open the file and review its contents, noting the database name (mediroza_hr), table structures, and embedded data.

Evidence

```
-- mediroza db backup 2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table 'staff'
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.aidoo@medirozahospital.com','+27 82 101 2007','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',120000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',50000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kgiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palisa Redebe','Radiographer','Radiology','p.redebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
```

Impact

The backup exposes, for all 30 hospital staff members: full name, job title, department, work email, phone number, national ID number, monthly salary, and date joined. It separately exposes confidential shareholder records for 10 shareholders, including shareholder name, share percentage, number of shares held, and share class. This satisfies both tasks required under Milestone 3 (staff salaries and shareholder details) and represents a severe breach of staff personal data, compensation confidentiality, and corporate shareholder confidentiality in a single exposed file.

4. Risk Rating

Each finding is rated Critical, High, Medium, or Low based on a qualitative assessment of exploitability (how easily an attacker can trigger the issue, and whether authentication is required) and impact (confidentiality, integrity, and availability consequences for patient, staff, and corporate data).

#	Finding	Exploitability	Impact	Rating	Justification
1	Username Enumeration	Low effort, unauthenticated	Low direct impact; enables targeting	Medium	Enables precise targeting of valid accounts (notably admin), directly feeding Finding 2.
2	SQL Injection — Auth Bypass	Trivial, unauthenticated, single payload	Full admin access	Critical	Grants unauthenticated attackers full administrative access; root cause of the entire chain.
3	Broken Access Control (PDFs)	Trivial once authenticated	Confidential patient data exposed	High	No authorization check beyond session validity; directly exposes patient lab reports.
4	Weak PDF Encryption	Low effort offline cracking	Confidential patient data recovered	High	Weak passwords provide no real protection once files are exfiltrated.
5	robots.txt Disclosure	Trivial, unauthenticated	Information disclosure only	Low	Does not expose data directly but reveals attack surface used in later findings.
6	Legacy Directory Live	Trivial, unauthenticated	Hosts further exposed data	Medium	Decommissioning failure that keeps an unreviewed path reachable in production.
7	Exposed Database Backup	Trivial, unauthenticated	Full staff PII, salaries, shareholder data	Critical	Single file exposes PII, national ID numbers, salaries, and shareholder records for the entire organisation.

Overall engagement risk: Critical. Two independent Critical findings (SQL injection and the exposed database backup) each provide a standalone path to severe data compromise, and together they confirm a complete, low-effort route from anonymous access to full breach of patient, staff, and shareholder data.

5. Recommendations and Remediation

The following remediation actions are mapped to each finding and ordered by priority. Critical and High items should be addressed immediately; Medium and Low items should be scheduled into the next maintenance cycle.

Finding 2 — SQL Injection (Critical)

- Replace dynamic/concatenated SQL queries with parameterised queries or prepared statements for all user-supplied input, starting with the login form.
- Deploy a web application firewall (WAF) as a defence-in-depth control while code fixes are rolled out.
- Conduct a full code review for the same unsafe query pattern elsewhere in the application.

Finding 7 — Exposed Database Backup (Critical)

- Remove the exposed backup file from any publicly reachable path immediately.
- Store database backups outside the web root, with access restricted to authorised administrators only.
- Encrypt backups at rest and rotate any credentials or identifiers that may have been exposed.
- Establish a backup lifecycle policy so old backups are deleted rather than left on production servers.

Finding 3 — Broken Access Control (High)

- Implement explicit, per-resource authorization checks (not just authentication checks) before serving any patient record.
- Apply the principle of least privilege so accounts only access records relevant to their role.

Finding 4 — Weak PDF Encryption (High)

- Enforce a strong password policy for any file-level protection, or replace file passwords with proper access-controlled storage and transport encryption.
- Avoid relying on document passwords as the sole protection for confidential patient data.

Finding 1 — Username Enumeration (Medium)

- Return generic, identical error messages and consistent response timing for both valid and invalid usernames.
- Implement account lockout or rate-limiting on repeated failed login attempts.

Finding 6 — Legacy Directory (Medium)

- Decommission and remove old directories and endpoints once they are no longer in active use, rather than leaving them reachable.
- Maintain an inventory of deployed paths/services to catch forgotten legacy assets.

Finding 5 — robots.txt Disclosure (Low)

- Do not rely on robots.txt to hide sensitive paths; remove or properly access-control the underlying resource instead.
- Avoid listing sensitive-sounding paths in robots.txt at all.

Networkwalks recommends the client prioritise remediation of the two Critical findings within 48 hours, with High findings addressed within two weeks, and Medium/Low findings incorporated into the next scheduled maintenance window. A follow-up retest is recommended once fixes are deployed to confirm the issues have been fully resolved.

This report is confidential and intended solely for authorised personnel of Mediroza General Hospital and Networkwalks. The techniques described were performed under explicit written authorisation and must never be applied to any system without the owner's written permission.